AUDITORIA DE CÓDIGO / 17 DE OUTUBRO DE 2026

Relatório de Auditoria de Segurança — CoreScope

Revisão estática do commit d2ad0ff · aplicativo pessoal para macOS

Escopo auditado

Aplicativo SwiftUI/AppKit local; núcleo Rust/C por FFI; persistência SQLite opcional; cliente Docker por socket Unix; subprocesso Codex CLI e statusline Claude opt-in; scripts de build, CI e release no GitHub Actions. Não há servidor HTTP próprio, rotas web, login, tenants, frontend HTML ou ORM.

Um delta concorrente em native/Agents.swift, native/Localization.swift e native/CodexThreads.swift foi conferido separadamente e não acrescentou achado confirmado. As referências de linha dos achados usam o HEAD d2ad0ff.

Nota metodológica

As cinco categorias solicitadas foram mapeadas à arquitetura real. Isolamento de tenant virou separação por UID e arquivos locais; autorização de backend virou proteção nas ações SwiftUI/notifications e na fronteira FFI; IDOR virou validação de identidades de processo e contêiner; segredos cobriram código, Git, app, distribuição e CI; XSS cobriu superfícies HTML/URL existentes. Foram reportados somente dois riscos verificados no código, sem forçar cinco achados.

Limite: as condições dependentes da tela bloqueada e de preferências de notificações não foram reproduzidas fisicamente; a evidência é o fluxo de código e o contrato do SDK. Nenhum sinal foi enviado a processos reais durante a auditoria.

Resumo executivo

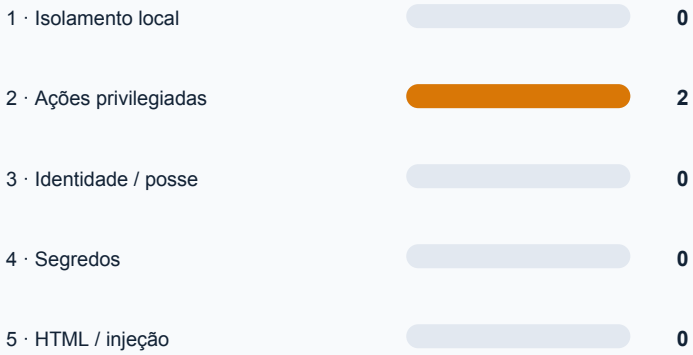
2 achados de severidade média. Ambos tratam de decisões de encerramento de processos na interface. O núcleo preserva checagens de UID, PID, instante de início e caminho do executável imediatamente antes de enviar o sinal.

0	0	2	0
Crítica	Alta	Média	Baixa

POR SEVERIDADE



POR CATEGORIA ADAPTADA



Leitura: os dois achados se concentram na categoria 2 adaptada às ações privilegiadas de uma GUI local. A1 permite escalar de SIGTERM para SIGKILL sem novo diálogo no aviso; A2 mantém um caminho de SIGTERM por notificação sem revalidar a preferência e sem exigir desbloqueio pela opção específica do SDK.

Critério de severidade

Média porque há ação explícita do usuário ou acesso físico condicionado, e as barreiras do núcleo limitam o alvo ao UID e à identidade revalidada. O impacto ainda inclui interrupção de processos e, em A1, perda de trabalho não salvo. Não foi demonstrada execução remota, escalada de privilégio do macOS ou acesso a processos de outro usuário.

Cobertura das cinco categorias

Categoria	Equivalente nesta stack	Resultado e evidência
1 · Banco sem tranca	Isolamento local por UID e diretórios do usuário; sem tenant/RLS.	Sem achado. core/src/lib.rs:585-619 e 1249-1269; histórico SQLite local opcional.
2 · Permissão no navegador	Confirmação e preferências da GUI/notifications antes de sinalizar.	A1 e A2. native/Design.swift:407-410; native/Notifier.swift:31-35 e 141-165.
3 · IDOR	Identidade de processo e contêiner; não há handlers HTTP próprios.	Sem achado. lib.rs:1249-1269; containers.rs:415-458.
4 · Chaves expostas	Código, histórico Git, app/distribuição e workflows.	Sem candidato reportável na varredura gitleaks; token CI dinâmico em release.yml:85.
5 · Inputs/XSS	SwiftUI Text/URLs; sem WebView, HTML ou templates de e-mail.	Sem achado. deep link validado em native/Agents.swift:42-45; porta UInt16 em Design.swift:379-386.

Pontos fortes verificados

● **Sinalização restrita** UID, PID, início, caminho e serviços protegidos são checados; duas leituras da identidade precedem o sinal.

core/src/lib.rs:585-619, 1249-1269

● **Contêiner sem ID ambíguo** ID hexadecimal e ação permitida são validados; o contêiner deve aparecer exatamente uma vez entre sockets resolvidos.

core/src/containers.rs:76-95, 415-458

● **Consultas locais parametrizadas** SQLite usa sqlite3_bind_* para valores externos; a consulta de histórico tem ordem escolhida em enumeração fixa.

core/src/sqlite.rs:138-162; history.rs:550-580

● **Entradas nativas delimitadas** Os oito pontos FFI exportados foram percorridos; ponteiros e operações são validados antes da execução.

core/src/lib.rs:1290-1432

● **Credenciais de CI** Checkouts desativam persistência de credenciais; release usa token transitório do GitHub Actions.

.github/workflows/ci.yml:22-24; release.yml:28-31, 83-85

Pontos fracos e achados detalhados

Os dois riscos estão na categoria 2 adaptada: a decisão visível ao usuário pode pular uma confirmação ou permanecer acionável após uma preferência ser desligada. A proteção do núcleo reduz o alcance, mas não substitui essa decisão da interface.

2 · Ações privilegiadas em interface local

Severidade	Arquivo:linha	Descrição e condição
MÉDIA	**A1** native/Design.swift:407-410 native/Models.swift:659-672, 674-705	Sobrevivente de SIGTERM + clique no aviso: SIGKILL é enviado diretamente, sem nova confirmação/aviso de perda de trabalho. O núcleo revalida a identidade.
MÉDIA	**A2** native/Notifier.swift:31-35, 141-165 native/PreferencesView.swift:241-247	Ação de notificação usa .destructive sem .authenticationRequired; resposta antiga após desativação não revalida a preferência. Tela bloqueada depende da exibição pelo macOS e não foi testada fisicamente.

Nota de precisão: o botão “Forçar (SIGKILL)” que já está dentro do diálogo de SIGTERM em native/Design.swift:447-448 é parte do diálogo; não foi contado como achado. O texto de risco do diálogo está em native/Models.swift:511-515.

Recomendações priorizadas

P1 A1 · Encaminhar o botão do aviso a confirmação de SIGKILL, com sobreviventes e perda possível explicitados.

P1 A2 · Exigir autenticação na ação de notificação, conferir a preferência ao receber resposta e retirar avisos de processo quando desligada.

P2 Adicionar testes para escalada do aviso, resposta antiga de notificação e cancelamento, usando sinais simulados.

P3 Conferir manualmente a apresentação da ação na tela bloqueada nas configurações de notificação oferecidas pelo macOS.

A tabela identifica os locais de correção; as issues abaixo trazem trechos literais, impacto e critérios verificáveis para abrir no GitHub.

ISSUES PARA O GITHUB

O Markdown completo entre os delimitadores está reproduzido abaixo e também em ISSUES.md ao lado deste PDF, pronto para copiar. Cada issue corresponde a um achado verificado; os dois subcasos de notificação estão agrupados em A2.

Issue 1 · severidade média

````
--- ISSUE 1 ---
# [Segurança] Confirmar SIGKILL ao escalar encerramento pelo aviso

Labels sugeridas: `security`, `medium`

## Problema e condição de exploração
Após uma tentativa de SIGTERM, o CoreScope mostra um aviso se o processo
continuar ativo. O botão "Forçar encerramento" desse aviso envia SIGKILL
com um clique. Ele chama `signal` diretamente, sem usar `requestKill`,
embora o contrato da UI diga que SIGKILL sempre exige confirmação.
Condição: o processo precisa sobreviver ao SIGTERM e o usuário precisa
clicar nesse aviso. O núcleo ainda revalida a identidade do processo.

## Evidência
`native/Design.swift:407-410`:
```swift
if !f.survivors.isEmpty {
  Button(L("Forçar encerramento")) {
    monitor.signal(f.survivors, force: true)
  }.buttonStyle(.borderedProminent).tint(.red).controlSize(.small)
}
```
`native/Models.swift:659-672` direciona SIGKILL a `pendingKill`;
`native/Models.swift:674-705` envia o sinal imediatamente em `signal`.

## Impacto
O usuário pode perder trabalho não salvo de um processo que ignorou
SIGTERM sem ver a confirmação e o aviso específico de SIGKILL.

## Sugestão de correção
Encaminhar a escalada do aviso ao mesmo modal de confirmação usado pela
ação Forçar da janela. Mostrar o nome/PID dos sobreviventes e que
SIGKILL encerra imediatamente com perda de trabalho não salvo.

## Critérios de aceite
- [ ] O clique no aviso abre confirmação e não envia SIGKILL ainda.
- [ ] O modal identifica os sobreviventes e explica a perda possível.
- [ ] Cancelar não chama `cs_signal`; confirmar chama apenas para os
      sobreviventes elegíveis.
- [ ] Teste automatizado cobre a rota do aviso sem sinalizar processos
      reais; a validação de identidade no núcleo continua ativa.
--- FIM ISSUE 1 ---
````

Issue 2 · severidade média

```
--- ISSUE 2 ---
# [Segurança] Proteger a ação Encerrar de notificações de processo

Labels sugeridas: `security`, `medium`

## Problema e condições de exploração
A ação "Encerrar" de uma notificação usa somente `.destructive`.
O SDK distingue essa marca visual de `.authenticationRequired`, que
exige desbloqueio antes de executar. Quando a ação chega ao delegado,
o código envia SIGTERM sem verificar novamente se o usuário desligou
as notificações/ações de processo. Desligar a opção só grava o toggle;
um aviso entregue antes disso pode continuar acionável.
Condições: aviso "Novo possível órfão" (`notifyOrphans`) previamente
ativado e permissão do macOS. A tela bloqueada exige que o sistema mostre a ação
nesse estado e alguém com acesso físico a escolha; isso não foi testado
fisicamente. O caminho do aviso antigo exige clicar depois de desligar.
O núcleo ainda revalida a identidade e o UID antes do SIGTERM.

## Evidência
`native/Notifier.swift:31-35`:
```swift
let kill = UNNotificationAction(
  identifier: Self.terminate, title: L("Encerrar"), options: [.destructive])
```
`native/Notifier.swift:141-165` encaminha a resposta a `terminate(id)`
e `monitor.signal([proc], force: false)` sem conferir preferências.
`native/PreferencesView.swift:241-247` não revoga avisos ao desligar.
`UNNotificationAction.h:16-20` define autenticação e marca destrutiva
como opções diferentes.

Impacto
Uma ação de notificação pode pedir o encerramento de um processo após
a opção ser desligada. Conforme a política de exibição do macOS, pode
também ser escolhida na tela bloqueada sem exigência explícita de
desbloqueio. Trata-se de SIGTERM, não SIGKILL.

Sugestão de correção
Registrar a ação com `.authenticationRequired` além de `.destructive`.
Revalidar `notifyOrphans` no delegado imediatamente antes do
sinal. Ao desligar, remover notificações de processo pendentes e
entregues; para avisos antigos, rejeitar a resposta no delegado.

Critérios de aceite
- [ ] A ação requer desbloqueio quando apresentada na tela bloqueada.
- [ ] Resposta de aviso antigo após desativação não chama `cs_signal`.
- [ ] Desligar "Novo possível órfão" remove seus avisos pendentes/entregues.
- [ ] Testes cobrem o toggle e uma resposta atrasada com sinal simulado.
- [ ] Teste manual no macOS confirma a apresentação na tela bloqueada.
--- FIM ISSUE 2 ---
```